SOC 2 Trust Services Criteria — Checklist

All 52 AICPA Trust Services Criteria: the 33 Common Criteria (CC1–CC9) required in every SOC 2 report plus the optional Availability, Processing Integrity, Confidentiality, and Privacy categories. Working reference by OG Technologies EU — not a substitute for the AICPA TSC or a formal examination.

CC1 — Common Criteria: Control Environment

Criterion	Title	In scope?	Evidence / Notes
CC1.1	Integrity and ethical values		
CC1.2	Board independence and oversight		
CC1.3	Structures and responsibilities		
CC1.4	Commitment to competence		
CC1.5	Accountability		

CC2 — Common Criteria: Communication and Information

Criterion	Title	In scope?	Evidence / Notes
CC2.1	Relevant quality information		
CC2.2	Internal communication		
CC2.3	External communication		

CC3 — Common Criteria: Risk Assessment

Criterion	Title	In scope?	Evidence / Notes
CC3.1	Objectives and risk identification		
CC3.2	Risk analysis and response		
CC3.3	Fraud risk		
CC3.4	Significant change		

CC4 — Common Criteria: Monitoring Activities

Criterion	Title	In scope?	Evidence / Notes
CC4.1	Ongoing and separate evaluations		
CC4.2	Deficiency communication		

CC5 — Common Criteria: Control Activities

Criterion	Title	In scope?	Evidence / Notes
CC5.1	Control selection and deployment		
CC5.2	Technology general controls		
CC5.3	Policies and procedures		

CC6 — Common Criteria: Logical and Physical Access

Criterion	Title	In scope?	Evidence / Notes
CC6.1	Logical access infrastructure		
CC6.2	User registration and authorization		
CC6.3	Access modification and removal		
CC6.4	Physical access		
CC6.5	Protection against removal		
CC6.6	Transmission and movement		
CC6.7	Data and media handling		
CC6.8	Malicious software prevention		

CC7 — Common Criteria: System Operations

Criterion	Title	In scope?	Evidence / Notes
CC7.1	Configuration and vulnerability detection		
CC7.2	Anomaly monitoring		
CC7.3	Security event evaluation		
CC7.4	Incident response		
CC7.5	Recovery and improvement		

CC8 — Common Criteria: Change Management

Criterion	Title	In scope?	Evidence / Notes
CC8.1	Authorized change		

CC9 — Common Criteria: Risk Mitigation

Criterion	Title	In scope?	Evidence / Notes
CC9.1	Risk mitigation activities		
CC9.2	Vendor and partner risk		

A1 — Availability (optional category)

Criterion	Title	In scope?	Evidence / Notes
A1.1	Capacity management		
A1.2	Availability commitments and recovery		
A1.3	Recovery testing		

PI1 — Processing Integrity (optional category)

Criterion	Title	In scope?	Evidence / Notes
PI1.1	Processing procedures		
PI1.2	Input completeness and accuracy		
PI1.3	Processing controls		
PI1.4	Output accuracy and distribution		
PI1.5	Storage of inputs and outputs		

C1 — Confidentiality (optional category)

Criterion	Title	In scope?	Evidence / Notes
C1.1	Identification and retention		
C1.2	Disposal		

P — Privacy (optional category, aligned to GAPP)

Criterion	Title	In scope?	Evidence / Notes
P1.0	Notice and communication		
P2.0	Choice and consent		
P3.0	Collection		
P4.0	Use, retention, and disposal		
P5.0	Access		
P6.0	Disclosure to third parties		
P7.0	Security for privacy		
P8.0	Quality		
P9.0	Monitoring and enforcement		